

CEH v13 MOCK EXAM 1

Knowledge Exam · 312-50

125 questions · 4 hours · single best answer

Target benchmark: 106/125 (≈85%)

Instructions

- **125 questions · 4 hours.** Pace $\approx$ 1 min 55 sec per question.
- Each question has exactly **one best answer**. Choose the single best option.
- No negative marking — never leave a question blank; flag and return if unsure.
- Answers are in the separate Answer Keys PDF. Do not open it until you finish.

Questions

- Q1.** Which element of information security ensures that a sender cannot later deny having sent a message?
- A. Non-repudiation
 - B. Availability
 - C. Confidentiality
 - D. Integrity
- Q2.** A company enforces full-disk encryption, hardware tokens, and strict application whitelisting, and users complain the systems are harder to use. Which principle best explains this outcome?
- A. Least privilege
 - B. Separation of duties
 - C. The security, functionality, and ease-of-use triangle
 - D. Defense in depth
- Q3.** An attacker compromises a workstation and uses it as a stepping stone to reach a database server deeper in the network. What is this technique called?
- A. Daisy-chaining
 - B. Island hopping recovery
 - C. Pivoting defense
 - D. Shrink-wrap attack
- Q4.** A tester is given no information about the target environment and must discover everything externally, simulating an outside attacker. Which test type is this?
- A. Credentialed test
 - B. Black-box test
 - C. White-box test
 - D. Gray-box test
- Q5.** An organization installs an IPS, deploys backups, and posts warning banners. Mapping these to control functions, which classification is correct?
- A. IPS detective, backup corrective, banner preventive
 - B. IPS recovery, backup deterrent, banner detective
 - C. IPS preventive, backup recovery, banner deterrent
 - D. IPS deterrent, backup preventive, banner corrective
- Q6.** Which footprinting activity involves NO direct interaction with the target's systems?
- A. Passive footprinting
 - B. Banner grabbing
 - C. Active footprinting
 - D. Port scanning
- Q7.** A penetration tester requests a full copy of a target's DNS zone and unexpectedly receives every host record. Which misconfiguration enabled this?
- A. DNSSEC misalignment
 - B. Unrestricted DNS zone transfer (AXFR)
 - C. Open SNMP community string
 - D. Reverse DNS disabled

Q8. Which DNS record maps a hostname to an IPv6 address?

- A. PTR
- B. AAAA
- C. A
- D. MX

Q9. A security analyst wants to confirm which mail servers accept mail for a domain. Which record should they query?

- A. CNAME
- B. NS
- C. SOA
- D. MX

Q10. An attacker inspects the full headers of a received email to learn the sending infrastructure. Which information is MOST likely revealed?

- A. Originating IP addresses and mail-server hops
- B. The SPF record of the recipient
- C. The recipient's password hash
- D. The DKIM private key

Q11. WHOIS privacy protection on a domain primarily hides which of the following?

- A. The web server's open ports
- B. The registrant's contact details
- C. The DNS A record
- D. The domain name itself

Q12. Which Nmap scan performs a half-open TCP scan that does not complete the handshake?

- A. -sU
- B. -sA
- C. -sS
- D. -sT

Q13. A tester runs a FIN scan against a target and receives no response on several ports. On an RFC-793-compliant host, how should these ports be interpreted?

- A. Unfiltered
- B. Definitely open
- C. Definitely closed
- D. Open or filtered

Q14. A FIN scan against a Windows host reports every port as closed, though services are clearly running. Why?

- A. The scan requires root privileges
- B. Windows randomizes TTL values
- C. Windows sends RST for both open and closed ports to these probes
- D. Windows blocks all ICMP

- Q15.** Which Nmap scan is used primarily to map firewall filtering rather than to find open ports?
- A. -sV
 - B. -sA
 - C. -sS
 - D. -sT
- Q16.** A target blocks ICMP echo, so Nmap reports all hosts as down. Which option lets the tester skip host discovery and scan them anyway?
- A. -R
 - B. -sn
 - C. -Pn
 - D. -PE
- Q17.** A default TTL value of 128 in a captured packet most likely indicates which operating system family?
- A. macOS
 - B. Linux/Unix
 - C. Cisco IOS
 - D. Windows
- Q18.** During a UDP scan, a probed port returns no response at all after retransmissions. What is the correct interpretation?
- A. Open or filtered
 - B. Closed
 - C. Open
 - D. Unfiltered
- Q19.** Which activity best describes enumeration as distinct from scanning?
- A. Actively extracting usernames, shares, and policies from a service
 - B. Identifying which hosts are alive
 - C. Mapping firewall rules
 - D. Capturing packets passively
- Q20.** An attacker connects to a Windows host's IPC\$ share without credentials to list users and shares. What is this technique called?
- A. Kerberoasting
 - B. DLL injection
 - C. Pass-the-hash
 - D. Null session
- Q21.** In SNMP, which default community string typically grants read-write access?
- A. private
 - B. admin
 - C. public
 - D. community

Q22. A tester uses the SMTP VRFY command during enumeration. What is the goal?

- A. Relay spam through the server
- B. Verify whether a username/mailbox exists
- C. Crack the mail password
- D. Encrypt the SMTP session

Q23. An analyst must enumerate exported file systems on a Linux server before mounting one. Which command is MOST appropriate?

- A. ldapsearch -x
- B. showmount -e
- C. snmpwalk -v2c
- D. nbtstat -A

Q24. Which port pair is associated with LDAP and LDAP over SSL/TLS, respectively?

- A. 137 and 139
- B. 88 and 464
- C. 161 and 162
- D. 389 and 636

Q25. Which standard provides a numerical severity score (0-10) for a vulnerability?

- A. CVE
- B. CVSS
- C. CWE
- D. CPE

Q26. A scanner reports a vulnerability that, on manual verification, does not actually exist. What is this result called?

- A. True positive
- B. True negative
- C. False positive
- D. False negative

Q27. A manager asks which scan result type is the most dangerous because it creates a false sense of security. Which should you cite?

- A. Informational finding
- B. False negative
- C. False positive
- D. True positive

Q28. To inspect installed patches, local configuration, and file permissions on a host, which scan type is required?

- A. External scan
- B. Passive scan
- C. Credentialed scan
- D. Non-credentialed scan

Q29. A CVSS base score of 9.3 falls into which severity band?

- A. High
- B. Critical
- C. Medium
- D. Low

Q30. On a Linux system, where are user password hashes normally stored?

- A. /etc/group
- B. /var/log/auth
- C. /etc/shadow
- D. /etc/passwd

Q31. Which file on a Windows system stores local account NTLM hashes?

- A. LSASS.log
- B. NTDS.dit
- C. SYSVOL
- D. SAM

Q32. An attacker authenticates to remote systems using a captured NTLM hash without ever cracking it. Which attack is this?

- A. Pass-the-ticket
- B. Golden ticket
- C. Pass-the-hash
- D. Kerberoasting

Q33. An attacker forges a Kerberos TGT using the krbtgt account hash, gaining domain-wide access. Which attack is described?

- A. Golden ticket
- B. Overpass-the-hash
- C. Silver ticket
- D. Pass-the-hash

Q34. Which tool is most associated with dumping credentials from LSASS memory and performing pass-the-hash?

- A. Ettercap
- B. Nikto
- C. Mimikatz
- D. Hydra

Q35. A forensic investigator finds a message hidden inside the least-significant bits of an image file. Which technique was used?

- A. Cryptography
- B. Steganography
- C. Hashing
- D. Tokenization

- Q36.** An attacker on a workstation exploits a weak file permission on a service that runs as SYSTEM to gain higher privileges. This is an example of what?
- A. Credential stuffing
 - B. Lateral movement
 - C. Vertical privilege escalation
 - D. Horizontal privilege escalation
- Q37.** Which password attack uses previously computed hash chains to reverse hashes quickly, and is defeated by salting?
- A. Credential stuffing
 - B. Dictionary attack
 - C. Rainbow table attack
 - D. Brute force attack
- Q38.** Which type of malware self-replicates and spreads autonomously across networks without needing a host file or user action?
- A. Rootkit
 - B. Worm
 - C. Trojan
 - D. Virus
- Q39.** Which malware component is specifically designed to conceal malicious code from antivirus detection?
- A. Payload
 - B. Crypter
 - C. Downloader
 - D. Dropper
- Q40.** A security team examines a suspicious binary by running it inside an isolated sandbox and observing registry, file, and network changes. Which analysis is this?
- A. Code signing
 - B. Dynamic analysis
 - C. Static analysis
 - D. Fuzzing
- Q41.** An incident involves malware that never writes an executable to disk and instead runs via PowerShell and WMI. Which category and key detection approach apply?
- A. Rootkit; secure boot
 - B. Boot-sector virus; signature AV
 - C. Fileless malware; behavioral/EDR monitoring
 - D. Macro virus; email filtering
- Q42.** In a typical crypto-ransomware design, how are the keys used?
- A. Only symmetric AES is used end to end
 - B. RSA encrypts files; AES encrypts the RSA key
 - C. Only RSA is used end to end
 - D. AES encrypts files; RSA/ECC encrypts the AES key

Q43. Which rootkit type operates at the lowest level, below the operating system, by running as or beneath a hypervisor?

- A. Library rootkit
- B. Hypervisor (virtualized) rootkit
- C. Kernel-mode rootkit
- D. User-mode rootkit

Q44. An organization faces a stealthy, well-funded, long-term intrusion that uses custom tools and maintains access for months. This is BEST described as what?

- A. A logic bomb
- B. A single trojan infection
- C. Adware
- D. An advanced persistent threat (APT)

Q45. Which of the following is classified as a potentially unwanted application (PUA) rather than confirmed malware?

- A. Kernel rootkit
- B. Ransomware
- C. Remote access trojan
- D. Adware/bundled toolbar

Q46. Which NIC mode allows a wired network card to capture all frames on the segment, not just those addressed to it?

- A. Managed mode
- B. Promiscuous mode
- C. Monitor mode
- D. Ad hoc mode

Q47. An attacker floods a switch with thousands of bogus source MAC addresses until it begins broadcasting traffic out all ports. Which attack is this?

- A. MAC flooding
- B. DNS poisoning
- C. DHCP starvation
- D. ARP spoofing

Q48. A CAM table on a switch maps which of the following?

- A. Domain name to IP
- B. Port number to service
- C. IP address to MAC address
- D. MAC address to switch port

Q49. Users on a LAN report their traffic is being intercepted; the attacker's host is sending forged replies claiming to own the gateway's IP. Which attack and best defense apply?

- A. MAC flooding; port security
- B. ARP spoofing; Dynamic ARP Inspection
- C. DNS spoofing; DNSSEC
- D. DHCP starvation; DHCP snooping

Q50. An analyst wants to see only HTTP traffic to host 10.0.0.5 in a capture. Which Wireshark display filter is correct?

- A. filter http 10.0.0.5
- B. capture http host 10.0.0.5
- C. http and ip.addr==10.0.0.5
- D. tcp.port=80 or ip=10.0.0.5

Q51. Which switch feature legitimately copies traffic from selected ports to a monitoring port for analysis?

- A. Trunking
- B. Port security
- C. Spanning Tree
- D. SPAN / port mirroring

Q52. A rogue device on the LAN hands out IP configuration with a malicious default gateway and DNS server. Which attack is occurring and which control stops it?

- A. Rogue DHCP; DHCP snooping
- B. ARP spoofing; static ARP
- C. STP attack; root guard
- D. MAC flooding; sticky MAC

Q53. An attacker enters a secure building by closely following an authorized employee through a door without the employee's knowledge. What is this called?

- A. Pretexting
- B. Tailgating
- C. Piggybacking
- D. Baiting

Q54. Which social-engineering attack uses a fabricated scenario or backstory to obtain information?

- A. Impersonation
- B. Shoulder surfing
- C. Dumpster diving
- D. Pretexting

Q55. An attacker calls employees pretending to be IT support and urgently requests their passwords to 'fix an outage.' Which triggers are primarily exploited?

- A. Consensus and reciprocity
- B. Scarcity and liking
- C. Fear of missing out only
- D. Authority and urgency

Q56. Finance receives an email appearing to come from the CEO urgently instructing a wire transfer to a new vendor account. Which attack is MOST likely?

- A. Smishing
- B. Vishing
- C. Business Email Compromise (BEC)
- D. Watering hole

Q57. Which email authentication mechanism publishes a policy telling receivers what to do with messages that fail SPF/DKIM?

- A. DKIM
- B. SPF
- C. DMARC
- D. TLS

Q58. What primarily distinguishes a DDoS attack from a DoS attack?

- A. It only works against web servers
- B. It targets confidentiality instead of availability
- C. It requires physical access
- D. It uses multiple distributed sources against the victim

Q59. An attacker sends many SYN packets and never completes the handshakes, exhausting the server's connection table. Which attack is this?

- A. SYN flood
- B. Smurf attack
- C. Slowloris
- D. UDP flood

Q60. An attacker sends small DNS queries with the victim's spoofed IP to open resolvers, which return much larger responses to the victim. Which two techniques are combined?

- A. Reflection and amplification
- B. Spoofing and sniffing
- C. Encryption and obfuscation
- D. Fragmentation and tunneling

Q61. Which attack permanently damages hardware, for example by corrupting firmware, so the device must be repaired or replaced?

- A. Slowloris
- B. SYN flood
- C. Teardrop
- D. Phlashing (PDoS)

Q62. A web server becomes unresponsive because an attacker opens many connections and sends partial HTTP headers very slowly, never completing requests. Which attack is this?

- A. DNS amplification
- B. HTTP GET flood
- C. LAND attack
- D. Slowloris

Q63. Which cookie attribute prevents client-side JavaScript from reading a session cookie?

- A. Secure
- B. SameSite
- C. HttpOnly
- D. Domain

- Q64.** What is the key difference between session fixation and session hijacking?
- A. Fixation forces a known session ID before login; hijacking steals an active one
 - B. Hijacking requires physical access
 - C. They are identical
 - D. Fixation only affects TCP; hijacking only HTTP
- Q65.** An attacker on the same network predicts TCP sequence numbers and injects packets into an established Telnet session. Which category of hijacking is this?
- A. CSRF
 - B. Application-level hijacking
 - C. Network-level hijacking
 - D. Session fixation
- Q66.** Which single countermeasure most directly defeats session fixation?
- A. Using long passwords
 - B. Regenerating the session ID after successful login
 - C. Disabling cookies entirely
 - D. Enabling gzip compression
- Q67.** How does spoofing differ from session hijacking?
- A. Hijacking only works over HTTPS
 - B. They are synonyms
 - C. Spoofing always requires malware
 - D. Spoofing impersonates a source; hijacking takes over an existing session
- Q68.** What is the primary functional difference between an IDS and an IPS?
- A. IDS is host-only; IPS is network-only
 - B. IDS blocks traffic; IPS only logs
 - C. There is no difference
 - D. IDS detects and alerts; IPS is inline and can block
- Q69.** An IDS that learns a baseline of normal traffic and flags deviations uses which detection method?
- A. Stateful inspection
 - B. Rule-based blacklist
 - C. Anomaly-based
 - D. Signature-based
- Q70.** An IDS raises an alert for normal, benign traffic. In the detection matrix, what is this outcome?
- A. True positive
 - B. False positive
 - C. False negative
 - D. True negative

Q71. An attacker splits malicious payloads across many tiny IP fragments to slip past signature detection. Which evasion technique is this?

- A. Port knocking
- B. Banner grabbing
- C. Packet fragmentation
- D. Source routing

Q72. Which detection location distinguishes a HIDS from a NIDS?

- A. HIDS is always inline; NIDS is passive
- B. HIDS monitors a single host; NIDS monitors network traffic
- C. They monitor the same scope
- D. HIDS only detects malware; NIDS only DoS

Q73. A decoy system is deliberately deployed to attract attackers and study their behavior while exposing no production data. What is it, and how does it differ from an IDS?

- A. A sinkhole; it reroutes DNS
- B. A WAF; it filters HTTP
- C. A honeypot; it attracts attackers, whereas an IDS monitors production traffic
- D. A bastion host; it blocks attackers

Q74. Which attack uses sequences like ../../ to access files outside the web server's root directory?

- A. Directory (path) traversal
- B. Cross-site scripting
- C. Clickjacking
- D. SQL injection

Q75. On a web server, what does the document root refer to?

- A. The directory from which website content is served
- B. The directory containing configuration files and binaries
- C. The TLS private key store
- D. The server's swap partition

Q76. A tester issues 'curl -I https://target' and reads the Server and X-Powered-By headers. Which activity is this?

- A. Banner grabbing / fingerprinting
- B. SQL injection
- C. Privilege escalation
- D. Session fixation

Q77. An application fetches a URL supplied by the user, and an attacker makes the server request http://169.254.169.254/ to read cloud metadata. Which web-server-side attack is this?

- A. CSRF
- B. Open redirect
- C. Stored XSS
- D. SSRF

Q78. Which tool is primarily a web server vulnerability scanner that checks for dangerous files and misconfigurations?

- A. Aircrack-ng
- B. Responder
- C. Nikto
- D. Mimikatz

Q79. In which XSS type is the malicious script permanently stored on the server and served to every visitor of a page?

- A. Stored (persistent) XSS
- B. Blind SQLi
- C. Reflected XSS
- D. DOM-based XSS

Q80. Which attack forces an authenticated user's browser to send an unwanted request to a site where they are logged in?

- A. CSRF
- B. XSS
- C. SSRF
- D. IDOR

Q81. A user changes the parameter `account_id=1001` to `account_id=1002` and views another customer's data with no additional check. Which vulnerability is this?

- A. Insecure Direct Object Reference (IDOR)
- B. SSRF
- C. Stored XSS
- D. CSRF

Q82. A web form validates input only with JavaScript in the browser. Why is this insufficient?

- A. It breaks the Secure cookie flag
- B. JavaScript is too slow
- C. It disables TLS
- D. Client-side checks can be bypassed with a proxy; validation must be server-side

Q83. In the OWASP Top 10 (2021), which category is ranked #1?

- A. Cryptographic Failures
- B. Security Misconfiguration
- C. Injection
- D. Broken Access Control

Q84. A tester must distinguish an attack where the server is tricked into making requests from one where the victim's browser is tricked. Which pairing is correct?

- A. Both are server-side
- B. Both are browser-side
- C. SSRF = server-side; CSRF = browser-side
- D. SSRF = browser-side; CSRF = server-side

Q85. Which web service component describes the operations and message format of a SOAP service?

- A. JSON
- B. REST
- C. UDDI
- D. WSDL

Q86. Which defense most directly mitigates reflected and stored XSS?

- A. Parameterized SQL queries
- B. Port knocking
- C. Disabling cookies
- D. Context-aware output encoding and a Content Security Policy

Q87. Which single countermeasure is the most effective defense against SQL injection?

- A. Rate limiting
- B. Parameterized (prepared) statements
- C. Disabling cookies
- D. A web application firewall

Q88. Which SQL injection technique infers data by observing differences in response timing rather than returned content?

- A. Error-based SQLi
- B. Time-based blind SQLi
- C. UNION-based SQLi
- D. Out-of-band SQLi

Q89. An attacker submits ' OR '1'='1 into a login field and is authenticated without valid credentials. Which SQLi pattern is this?

- A. Tautology-based authentication bypass
- B. Stored procedure overflow
- C. Out-of-band exfiltration
- D. Second-order injection

Q90. A tester injects a UNION SELECT to append attacker-chosen columns to the application's result set. For this to work, what must be true?

- A. The server must run as root
- B. The database must be MySQL only
- C. Error messages must be disabled
- D. The injected query must match the column count and compatible types

Q91. Which tool is primarily used to automate SQL injection detection and exploitation?

- A. Hydra
- B. Kismet
- C. sqlmap
- D. Nikto

- Q92.** An application returns identical pages regardless of input, but the tester can still extract data by asking true/false questions and watching behavior. Which SQLi category is in use?
- A. Error-based
 - B. UNION-based
 - C. Boolean-based blind
 - D. In-band
- Q93.** Why should applications suppress detailed database error messages?
- A. To prevent error-based SQL injection from leaking schema details
 - B. To enable UNION attacks
 - C. To comply with TLS requirements
 - D. To improve performance
- Q94.** Which wireless encryption standard uses RC4 with a 24-bit initialization vector and is considered broken?
- A. WPA2
 - B. WEP
 - C. WPA
 - D. WPA3
- Q95.** What is the difference between a rogue access point and an evil twin?
- A. A rogue AP only affects 5 GHz; evil twin only 2.4 GHz
 - B. An evil twin is always wired
 - C. They are identical
 - D. A rogue AP is an unauthorized AP on the network; an evil twin impersonates a legitimate SSID
- Q96.** An attacker sends forged deauthentication frames to a client to force it to reconnect and capture the 4-way handshake. What is the goal?
- A. To exhaust the DHCP pool
 - B. To crack the WPA2 PSK offline
 - C. To spoof DNS
 - D. To poison the ARP cache
- Q97.** A company wants per-user wireless credentials and central authentication via RADIUS. Which mode should they deploy?
- A. WPA2/WPA3-Enterprise (802.1X)
 - B. WPA2-Personal (PSK)
 - C. WEP with shared key
 - D. Open with MAC filtering
- Q98.** Which Bluetooth attack involves stealing data from a device over Bluetooth?
- A. Bluejacking
 - B. Bluebugging
 - C. Bluesnarfing
 - D. Bluesmacking

Q99. Which tool suite is most associated with capturing wireless handshakes and cracking WEP/WPA keys?

- A. John the Ripper
- B. Nessus
- C. Aircrack-ng
- D. Burp Suite

Q100. A WPA2-PSK network resists an attacker's offline dictionary attack poorly, while a neighboring WPA3-Personal network does not. Which WPA3 mechanism is responsible?

- A. WPS
- B. SAE (Simultaneous Authentication of Equals)
- C. TKIP
- D. CRC-32

Q101. On which mobile platform does 'jailbreaking' remove vendor restrictions?

- A. iOS
- B. Android
- C. Windows Phone
- D. Both equally, called rooting

Q102. An attacker takes a legitimate app, inserts malware, and republishes it on a third-party store. Which risk is this?

- A. SIM swapping
- B. Jailbreak detection bypass
- C. Repackaged (trojanized) application
- D. Sandbox escape

Q103. What is the primary purpose of Mobile Device Management (MDM) in an enterprise?

- A. To jailbreak devices for testing
- B. To sniff cellular traffic
- C. To crack mobile app encryption
- D. To enforce policy, encryption, and remote wipe on managed devices

Q104. Analyzing a mobile incident, you note the chain moved from a compromised app on the phone, through an open Wi-Fi MITM, to the backend API. Which model does this illustrate?

- A. The cyber kill chain only
- B. The device/network/data-center mobile attack surface
- C. The Purdue model
- D. The OSI model

Q105. Which feature isolates a mobile application's data from other apps on the device?

- A. Rooting
- B. Tethering
- C. NFC
- D. App sandboxing

Q106. Which item is listed as the number-one risk in the OWASP IoT Top 10?

- A. Lack of physical hardening
- B. Weak, guessable, or hardcoded passwords
- C. Insecure network services
- D. Insufficient privacy protection

Q107. In OT/ICS environments, which security property is typically prioritized highest?

- A. Non-repudiation
- B. Integrity
- C. Confidentiality
- D. Availability/safety

Q108. A massive DDoS is traced to IoT cameras and DVRs infected because owners never changed default credentials. Which botnet behavior does this exemplify?

- A. Conficker
- B. Stuxnet
- C. Mirai
- D. SQL Slammer

Q109. A security team must protect legacy SCADA systems that use unauthenticated protocols. Which control is MOST appropriate?

- A. Network segmentation / isolating IT from OT
- B. Installing adware filters
- C. Enabling verbose logging only
- D. Requiring CAPTCHAs

Q110. Which lightweight publish/subscribe protocol is commonly used by IoT devices?

- A. SNMPv3
- B. SMTP
- C. MQTT
- D. RDP

Q111. In which cloud service model does the customer manage the most of the stack, including the OS and applications?

- A. IaaS
- B. PaaS
- C. SaaS
- D. FaaS

Q112. Under the cloud shared responsibility model, which is ALWAYS the customer's responsibility regardless of service model?

- A. Their own data, identities, and configuration
- B. Physical data-center security
- C. The hypervisor
- D. The underlying network hardware

Q113. An attacker exploits an SSRF flaw to reach the instance metadata endpoint and steal temporary IAM credentials. Which endpoint is targeted?

- A. 10.0.0.1
- B. 127.0.0.1
- C. 8.8.8.8
- D. 169.254.169.254

Q114. Which statement best distinguishes a container from a virtual machine?

- A. A container shares the host kernel and is lighter than a VM
- B. They are identical technologies
- C. A VM shares the host kernel
- D. A container includes a full guest OS and a hypervisor

Q115. Which is the leading cause of real-world cloud data exposures highlighted in CEH material?

- A. Quantum attacks
- B. Misconfiguration (e.g., public storage buckets)
- C. Physical theft of servers
- D. Zero-day hypervisor exploits

Q116. In a cloud SOAP-based service, an attacker modifies a signed message so that a malicious operation is processed as if legitimate. Which attack is this?

- A. Wrapping attack
- B. Man-in-the-cloud
- C. Side-channel attack
- D. Cryptojacking

Q117. Which algorithm is a symmetric block cipher and the current encryption standard?

- A. Diffie-Hellman
- B. SHA-256
- C. RSA
- D. AES

Q118. To create a digital signature, which key does the signer use?

- A. The recipient's private key
- B. The recipient's public key
- C. A shared symmetric key
- D. The signer's private key

Q119. Alice wants only Bob to read a message she sends him using asymmetric cryptography. Which key does she encrypt with?

- A. Bob's public key
- B. Bob's private key
- C. Alice's public key
- D. Alice's private key

Q120. A password database was stored as unsalted MD5. Which attack is MOST accelerated by this choice, and what control would have prevented it?

- A. Rainbow table attack; salting
- B. Brute force; shorter hashes
- C. Side-channel; constant-time compare
- D. Birthday attack; longer keys

Q121. Which of the following is a stream cipher?

- A. AES
- B. RC4
- C. Blowfish
- D. 3DES

Q122. A browser trusts a website's certificate because it chains to a recognized authority. What distinguishes this from a self-signed certificate?

- A. Self-signed certs use stronger keys
- B. CA-signed certs never expire
- C. CA-signed certs chain to a trusted authority; self-signed provide no third-party trust
- D. Self-signed certs cannot be used with TLS

Q123. In the context of quantum computing, which algorithm threatens the security of RSA and ECC specifically?

- A. Shor's algorithm
- B. Grover's algorithm
- C. SHA-3
- D. AES-256

Q124. Which blockchain attack involves a single party controlling the majority of mining/hash power?

- A. 51% attack
- B. Race attack
- C. Finney attack
- D. Eclipse attack

Q125. An HMAC is used to protect API messages between two services sharing a secret key. Which property does HMAC NOT by itself provide?

- A. Message authentication
- B. Non-repudiation
- C. Tamper detection
- D. Integrity